

SIKAFLOW – INCIDENT RESPONSE PLAYBOOK

Group 3 – Thrive Africa Cybersecurity Internship

Week 6: Incident Response & Security Operations

Date: May 2026

1. Introduction

This document defines the Incident Response Playbook for SikaFlow, a fintech organization handling sensitive financial transactions and customer data. It provides a structured, practical, and time-sensitive approach to managing cybersecurity incidents.

The goal is not only to respond to incidents, but to minimize financial loss, protect customer data, and ensure rapid service recovery.

2. Purpose

- Provide a clear and actionable response framework
 - Reduce incident impact on critical financial systems
 - Ensure fast containment and recovery
 - Support compliance and forensic investigation
-

3. Scope

Applies to:

- Core systems (payment servers, authentication systems)
 - Databases (customer and financial records)
 - APIs and web applications
 - Network infrastructure (Firewall, IDS, SIEM)
 - Employees and privileged users
-

4. Incident Classification Table -SikaFlow

Severity Level	Description	Examples (SikaFlow Context)	Affected Assets	Response Time (SLA)	Escalation Level
Low	Minimal impact, no significant disruption to operations	Failed login attempts, minor alerts, low-risk vulnerability detection	User accounts, endpoints	Within 4 hours	Security Team
Medium	Limited impact on a single system or user, no major business disruption	Malware on one workstation, suspicious internal activity	Endpoints, internal systems	Within 1 hour	IT Manager
High	Significant system impact or potential security breach affecting services	API attack, unauthorized access to internal systems, service disruption	Application servers, APIs, network systems	Within 30 minutes	IT Manager + Management
Critical	Severe impact involving financial systems, sensitive data, or full system compromise	Database breach, payment system compromise, ransomware attack, root access (e.g., bind shell)	Payment systems, databases, authentication systems	Within 15 minutes	Full Escalation (Management + Legal/Compliance)

5. Asset-Based Prioritization

Incidents are prioritized based on affected assets:

Critical Assets:

- Payment Processing Server
- Customer & Transaction Databases
- Authentication Systems

☞ Any incident affecting these assets is automatically classified as **High or Critical**.

6. Incident Types Relevant to SikaFlow

- Unauthorized Access / Credential Theft
- Data Breach (Customer or Financial Data)
- Malware / Backdoor Attack

- API / Web Application Attack
 - DDoS / Service Disruption
 - Insider Threat
-

7. Roles and Responsibilities

Role	Responsibilities
Security Team	Monitor alerts (SIEM/IDS), detect incidents, initial analysis
System Administrators	Containment, patching, system recovery
IT Manager	Coordinate response and escalation
Management	Approve major decisions
Legal/Compliance	Handle regulatory reporting and evidence

8. Communication and Escalation Plan

8.1 Communication Flow

Security Alert → Security Team → IT Manager → Management

8.2 Escalation Rules

- Low → Security Team
 - Medium → IT Manager
 - High → Immediate escalation to Management
 - Critical → Full escalation (Management + Legal/Compliance)
-

9. Incident Response Lifecycle

9.1 Identification

Detection sources:

- Security Information and Event Management alerts (log correlation)
- Intrusion Detection Systems alerts
- Firewall alerts
- User reports

☞ All alerts must be logged and time-stamped.

9.2 Classification & Triage

Classification Rules

- Any incident affecting **critical assets** (payment systems, databases, authentication servers) is automatically classified as **High or Critical**
 - Incidents involving **data breaches or financial systems** must be treated as **Critical**
 - Multiple affected systems increase severity level
 - Repeated or persistent attacks may escalate severity
-

Usage

This classification table is used during the **Identification and Triage phase** of the Incident Response Process to:

- Determine severity level
- Assign response priority
- Trigger appropriate escalation and actions

9.3 Containment

Short-Term:

- Isolate affected system from network
- Disable compromised accounts (Identity and Access Management)
- Block malicious IPs (Firewall)

Long-Term:

- Network segmentation
 - Apply security rules to prevent spread
-

9.4 Eradication

- Remove malware, backdoors, and unauthorized access
 - Patch vulnerabilities (e.g., outdated Apache, SMB)
 - Disable insecure services (Telnet, FTP backdoor)
 - Reset all compromised credentials
-

9.5 Recovery

- Restore systems from secure backups
 - Monitor via SIEM for abnormal activity
 - Validate system integrity before going live
-

9.6 Evidence Handling & Logging

- Preserve system logs, access logs, and network traffic
- Document all actions taken during response
- Ensure evidence integrity for forensic analysis

9.7 Post-Incident Review

- Identify root cause
 - Evaluate response effectiveness
 - Update detection rules and security controls
 - Document lessons learned
-

10. INCIDENT-SPECIFIC PLAYBOOKS

10.1 Unauthorized Access / Credential Theft

- Detect: SIEM alerts for suspicious login
 - Contain: Disable account (IAM)
 - Eradicate: Reset credentials, enforce MFA
 - Recover: Restore secure access
-

10.2 Data Breach (Database Compromise)

- Detect: Abnormal database queries (SIEM)
 - Contain: Isolate database server
 - Eradicate: Patch vulnerabilities, secure access
 - Recover: Restore and verify data integrity
-

10.3 Malware / Backdoor Attack

- Detect: Unusual processes, backdoor access
- Contain: Disconnect affected system
- Eradicate: Remove malware, rebuild system if needed
- Recover: Restore from backup

10.4 API / Web Application Attack

- Detect: Abnormal API traffic
- Contain: Block IPs, enable rate limiting
- Eradicate: Patch API vulnerabilities
- Recover: Restore services and monitor

10.5 Distributed Denial Of Service / Service Disruption

- Detect: Traffic spikes
- Contain: Firewall filtering, traffic throttling
- Eradicate: Block attack sources
- Recover: Restore service availability

10.6 Insider Threat

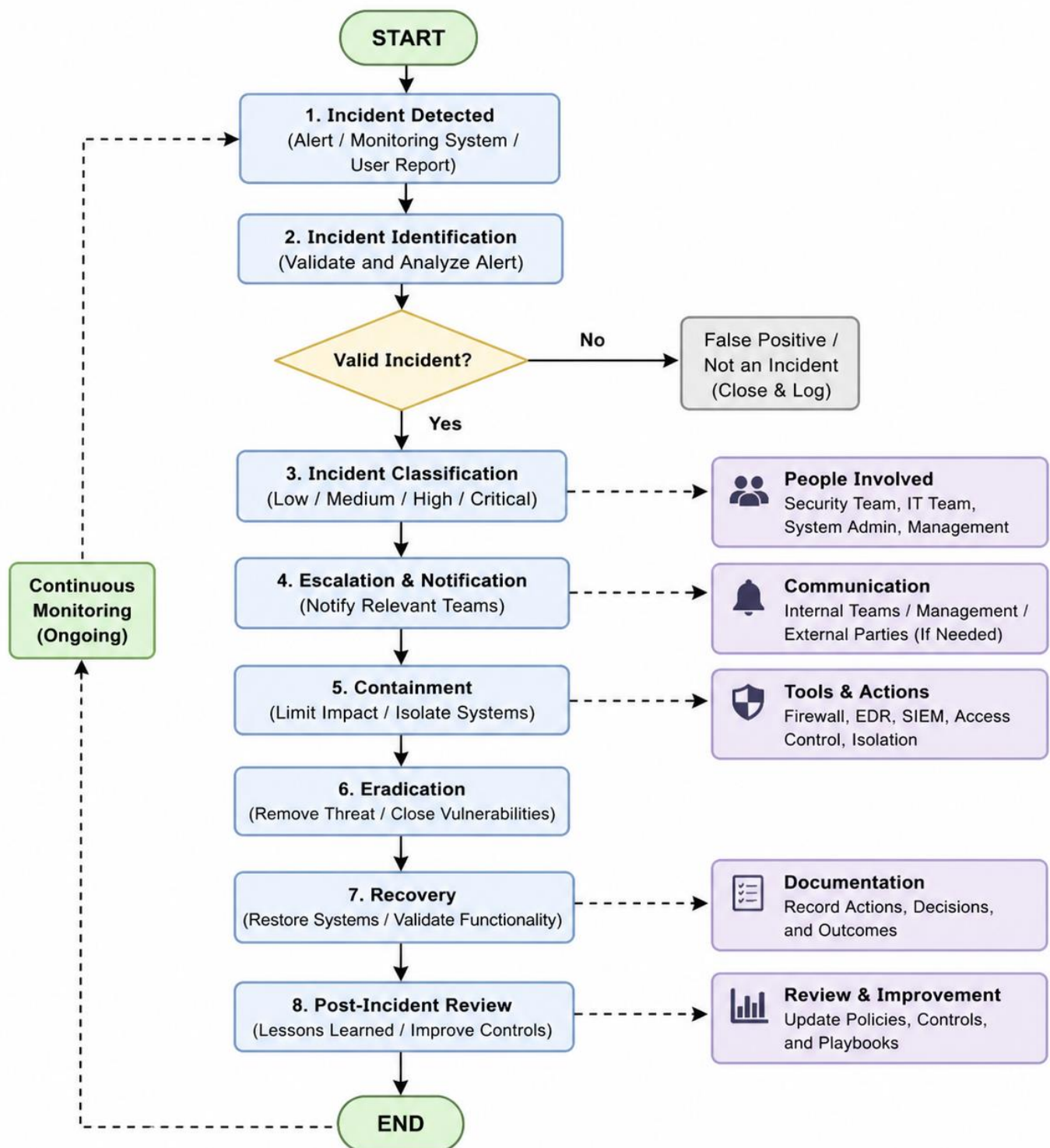
- Detect: Suspicious admin activity
- Contain: Revoke access immediately
- Eradicate: Investigate actions taken
- Recover: Reinstate secure operations

11. Incident Workflow Diagram

Incident Response Process Overview

This diagram illustrates a structured incident response lifecycle for SikaFlow used to detect, analyze, and resolve security or operational incidents efficiently. The process begins with identifying potential incidents through alerts or user reports, followed by validation to determine whether the issue is genuine. Once confirmed, incidents are classified based on severity and escalated to the appropriate teams for action.

The workflow then focuses on containing the incident to minimize impact, eliminating the root cause, and restoring affected systems to normal operation. After recovery, a post-incident review is conducted to capture lessons learned and improve future response strategies. Continuous monitoring is maintained throughout the process to ensure early detection and ongoing system security.



12. Conclusion

This enhanced Incident Response Playbook provides a realistic, structured, and time-sensitive framework tailored to SikaFlow's fintech environment. By incorporating asset prioritization, response timing, and evidence handling, the organization is better equipped to respond effectively to cybersecurity incidents and minimize operational and financial impact.